Sovereign University IT — Operational Summary

Reference Architecture, Migration Waves and Acceptance Gates, at a Glance

For the CISO, the CTO, and infrastructure / network team leads

Operational companion to: *"Sovereign University IT — A Technical Reference for Architecture and Migration"*

Document Version 2.1 / May 2026 • Print date: June 9, 2026

First version created by Nicolas Guelfi, Chairman of the SUIT Working Group.

Nine layers, three planes, ten waves — each wave reversible, each closure proven by conformance, every component replaceable through a published interface.

Operational synopsis

We are standing up a **vendor-neutral reference architecture** for university IT and a **brownfield migration playbook** to reach it from whatever estate exists today. In operational terms: a small, strongly protected core (identity, observability, network backbone) is established first; authorisation is lifted out of scattered application logic and identity-provider-native rules into a single Policy Decision Point (PDP); the network is carved into declared zones; and every workload, session and access decision is bound to a Trusted Activity Context (TAC) — a validated bundle of subject, action, resource and context that the platform can activate, audit and tear down as a unit. The architecture's normative content is a set of **interface contracts** (OIDC/SCIM, RADIUS, NETCONF/YANG, the Kubernetes and S3 APIs, OpenTelemetry, KMIP/ACME), not a product list: open-source instantiations prove the contracts are realisable, and any compliant component — proprietary or open — is admissible. The migration is delivered as **ten waves** under a dependency graph, each with a coexistence (shadow / dual-stack) pattern, a declared reversibility window, and conformance-based exit gates. The pay-off for operations is concrete: incidents are bounded by TAC instead of cascading through a flat perimeter, suppliers are swapped through a rehearsed exit rather than a forklift, and "done" is a passing test rather than a declaration.

▷ *Full treatment, contracts and references: Chapter 1 (*Synthesis*) of the Technical Reference, in the Technical Reference [1].*

Reference architecture at a glance: nine layers, three planes

Plane	Layers	Operational role / primary contract
Subject & Trust	Identity (Ch. 6), Endpoint (Ch. 11), Crypto (Ch. 13)	Who is acting, from where, with what assurance. OIDC/SAML2/SCIM 2.0; posture schema; PKCS#11/ACME/KMIP. Read by the Control plane.
Execution	Network (Ch. 8), Compute (Ch. 9), Storage (Ch. 10)	Where activity runs and on which data. RADIUS + NETCONF/YANG + IPFIX; Kubernetes/OpenStack/OCI; S3/NFS/KMIP. Written by the Control plane.
Control & Governance	Policy (Ch. 7), Observability (Ch. 12), Orchestration (Ch. 14)	How decisions are made, recorded and executed. PDP verdict `{verdict, obligations, policy_version}`; OpenTelemetry + canonical TAC schema; cross-layer TAC activation (no single standard).

Table 1: The reference architecture: nine functional layers grouped in three planes. Two regular flows govern it — the Subject & Trust plane feeds the Control plane (identity, posture and crypto parameterise policy); the Control plane writes to the Execution plane (decisions enforced at Network, Compute, Storage; Orchestration realises them; Observability collects evidence of every crossing).

Operating rule: contracts, not products

Procurement and acceptance reference *standards*, not product names. A component is in production only when it speaks its layer's interface contract and is **replaceable**: standard interfaces with no captive extensions in the critical path, open state/config formats, a documented exit-data export within an agreed window, and no hidden supplier sidecars. The one honest gap is Orchestration: no single standard yet exists, so the cross-layer "glue" is bounded deliberately to avoid creating a new captive dependency.

▷ *Full treatment, contracts and references: Chapter 5 (*Architectural principles*) of the Technical Reference and the per-layer chapters 6–14, in the Technical Reference [1].*

Migration sequence: ten waves, dependencies, reversibility

The waves are not calendar phases; they unfold under a dependency graph that permits parallelism. **Wave 0** is the entry point for every trajectory. After it, Waves 1–3 (Identity, Observability, Network) may run in parallel if staffing allows; Wave 4 (Policy) needs Identity and Observability; Wave 5 (Pilot) is the first end-to-end exercise on a contained scope. **Every wave is reversible at acceptable cost during a published window** — the coexistence pattern is the reversal mechanism: as long as the incumbent stays viable, the wave is undone by re-routing to it.

Minimal coherent core — if resources are constrained

A constrained team may legitimately adopt **less**, not later: Wave 0 (governance/inventory) + Wave 1 (sovereign identity) + Wave 2 (observability / audit trail), with Wave 4 (policy) the natural next step. This delivers exactly the size-invariant, legally compelled functions (authentication, audit, segmentation discipline under General Data Protection Regulation (GDPR) and, where in scope, NIS2 Directive (NIS2)) and is a legitimate *steady state*, not an abandoned migration. Defer or mutualise the rest along the same dependency graph.

▷ *Full treatment, contracts and references: Chapter 17 (*How to read this playbook*) of the Technical Reference and the wave chapters 18–27, in the Technical Reference [1].*

Conformance & replaceability: the acceptance gates

A contract that cannot be checked is a slogan. Each wave closes by passing the conformance subset for its scope — never by the judgement that "the migration is done". This is the single mechanism that prevents the classic failure mode: **a product swap disguised as architectural progress**.

How to run it

Run a time-boxed **conformance day**: one engineer per affected layer, one observability operator to retrieve replay material, a note-taker, the scope owner. Half a day per layer; one day for a full review. Output is a structured report (pass / conditional pass / fail, with evidence and remediation owner) and an **exit-confidence index** per layer on the 0–3 grid scale. The index is a *maturity trajectory*, not a day-one gate: a layer consumed as a managed/mutualised service answers replaceability through the provider's contractual exit terms, not a self-run test.

▷ *Full treatment, contracts and references: Chapter 16 (*Conformance and replaceability tests*) of the Technical Reference, in the Technical Reference [1].*

Sizing reference points (R-tier institution) for capacity planning

Status of these figures

Indicative orders of magnitude for a **research-intensive (R-tier)** reference profile: ∼25,000 active subjects, ∼1,500 elevated-access staff, ∼500 active research projects. These are *planning aids, not measurements*; size your own estate by direct workload measurement.

Wave	Operational goal	Requires	Reversibility window
0 — Foundations	Mandate, governance body, sovereignty grid adopted, baseline inventory. No technical change.	—	Highest; decisions informational, not binding.
1 — Identity	Sovereign IdP on OIDC/SAML2/SCIM, R&E federation, reviewable attribute schema, ingestible auth log.	0	Throughout cutover; ∼6–12 months after final cohort.
2 — Observability	Collector layer emitting canonical TAC schema; portable ingestion; retention schedule.	0	Structural; remove collectors to revert.
3 — Network	Declared zone catalogue, RADIUS attachment, NETCONF/YANG config, IPFIX, Science DMZ where warranted.	0 (rec. 2)	Per-segment, ∼3–6 months after each cut-over.
4 — Policy	PDP deployed; selected decisions migrated from app/IdP logic; authoring/review process.	1, 2 (rec. 3)	Per-policy, while shadow observation continues.
5 — Pilot	One or more TACs in production on contained scope; extract learnings.	1,2,3,4	Structural; stop the pilot at any time.
6 — Endpoint	Unified posture schema across OSes routed into the policy plane; decommissioning integrated.	1, 4 (rec. 2,5)	Per-policy and per-population.
7 — Audit & IR	TAC-correlated investigation, refreshed IR runbooks, routine audit replay.	2,4,5	Structurally additive; revert at boundary.
8 — Workload	Classification as authoritative input to provisioning, storage binding, policy; cluster-separation rule.	1,3,4 (rec. 5)	Per-workload, for the coexistence duration.
9 — Lifecycle	Self-service TAC provisioning, GitOps as source of truth, stability metrics.	1–8 in some form	Per-consumer-group.

Table 2: Wave sequence with required pre-requisites and indicative reversibility windows. Pace options: *5-year compressed* (parallelised, higher risk tolerance), *7-year balanced* (recommended default), *10-year gradual* (renewal-aligned, lower risk). Trajectory varies by starting estate (greenfield, brownfield Microsoft-centric, brownfield hybrid, selective, deferred).

Test category	What the gate verifies (operationally)
Interface fidelity (F)	The component speaks the standard correctly (e.g. OIDC discovery metadata conformant; Kubernetes upstream conformance passes; NETCONF apply without the vendor console).
Data portability (P)	Data/config export in a documented open format and re-import into an alternative without loss (SCIM export to an alternative IdP; OCI image digest preserved; KMIP key migration).
Exit rehearsal (X)	The replacement is *rehearsed*, not simulated: an alternative restores service on a representative subset within the documented window.
Decision auditability (A)	A recorded decision replays against its recorded inputs and policy version to the identical verdict; TAC deactivation reverses every recorded change.

Table 3: The four acceptance-gate categories, mapped to the four conditions of replaceability. Wave-to-test mapping is published per wave; e.g. Wave 1 closes against the four Identity tests, Wave 3 against the four Network tests, Wave 5 against the union exercised by the pilot.

Layer	Indicative reference points	Run FTE (shared)
Identity	Auths/s: a few–tens steady, hundreds at peak; concurrent sessions thousands; eduGAIN tens–hundreds of thousands/day.	2–4
Policy	Tens–low hundreds decisions/s; <10 ms p95 online decision; bundle refresh in minutes.	1–2
Network	Backbone 40–400 Gb/s aggregate; Science DMZ at backbone order; IPFIX hundreds of millions of records/day.	3–5
Compute / Storage	OpenStack + Kubernetes; Ceph multi-PB; per-class cluster separation.	4–7 / 2–4
Observability	Tens–hundreds of millions of events/day; tens–low hundreds of GB/day compressed; 90d hot / 1y warm / multi-year cold.	3–5

Table 4: Selected sizing reference points and indicative run-time engineer-equivalents per layer (ranges are *not additive*; staff are shared across layers). The build phase adds ∼1–2 FTE per active wave.

Scaling breakpoints (reshape the instantiation, not the architecture): Identity > ∼50k subjects → horizontal partitioning; Audit > ∼500 GB/day → hot/warm/cold tier separation; Policy > ∼5,000 decisions/s → per-app sidecars; Storage > multi-PB → Ceph federation. **Down-scaling** reads the same logic backward: a teaching-led institution collapses planes to logical segments on shared hardware, mutualises compute/storage via a national research cloud or R&E service, and defers the optional Science DMZ — a minimal-core envelope of ∼3–5 shared engineer-equivalents.

▷ *Full treatment, contracts and references: Chapter 15 (*Sizing reference points*) of the Technical Reference, in the Technical Reference [1].*

Top operational risks, mitigations, and coexistence patterns

Operational risk	Mitigation
★ Product swap mistaken for architectural progress	Close every wave on its conformance subset (F/P/X/A); a new IdP that fails data-portability and exit-rehearsal has not closed the wave.
★ Long-running dual stack with no exit date	Declare the exit date at wave open; track it in programme governance; escalate on drift.
★ Bridge fails silently (sync job stops, metadata expires)	Name the bridge owner explicitly at wave open, with a documented escalation path; surface discrepancies through observability.
★ Bidirectional sync without conflict resolution	Prefer unidirectional sync; where bidirectional is unavoidable, document and test an explicit conflict-resolution rule before production.
★ Coexistence frozen as de-facto architecture	Periodic review under the sovereignty grid; a coexistence unrevisited for 24 months is re-evaluated against current cost/benefit.
★ Reversibility forfeited under delivery pressure	Forfeit only on explicit written acceptance by the competent governing authority, against the grid, revisited at every renewal.

Table 5: Top operational risks during migration and their mitigations.

Shadow-mode and coexistence patterns to standardise on

- **Incumbent directory ↔ institutional IdP:** directory stays authoritative; new IdP federates via SAML2/OIDC; *unidirectional* sync only.
- **Policy shadow mode:** the PDP logs decisions with the same fidelity as enforcing mode before any decision becomes binding — the safe path to flip enforcement.
- **Per-volume Security Information and Event Management (SIEM) ↔ open store:** hot investigative window in the commercial SIEM; long-tail retention in the open store; dashboards migrate on financial, not technical, triggers.
- **Commercial hypervisor ↔ open substrate; enterprise array ↔ distributed storage:** new workloads default to the open side; legacy migrates at its natural lifecycle boundary, validated by checksum.
- **eduroam ↔ TAC-aware Wi-Fi:** keep the eduroam profile inviolate; add institutional/TAC attributes only on the non-eduroam path.

▷ *Full treatment, contracts and references: Chapter 29 (*Reversibility playbook*) of the Technical Reference and Chapter 30 (*Coexistence patterns library*) of the Technical Reference, in the Technical Reference [1].*

What this means for the operational teams

Operational call to action

1. **Start with Wave 0:** adopt the sovereignty grid as the procurement/acceptance instrument and complete the baseline inventory — organisational, zero technical risk, but every later wave inherits it.
2. **Stand up the minimal core** (Identity + Observability), then the Policy plane in shadow mode, before touching the network fabric.
3. **Make conformance the definition of done:** schedule conformance days, publish the exit-confidence index, and refuse to close a wave on declaration alone.
4. **Write procurement against contracts, not products,** and rehearse the exit at least once per layer per year — replaceability is only real once exercised.

Full document: *"Sovereign University IT — A Technical Reference for Architecture and Migration"* [1] develops the five-dimension sovereignty grid, the Trusted Activity Context, the nine-layer / three-plane reference architecture on open foundations, the ten-wave migration playbook with per-wave trajectories and reversibility, the conformance suite, the sizing reference points, and the regulatory mapping (GDPR, NIS2, the EU AI Act, eIDAS 2, Schrems II) against the jurisdiction-neutral standards spine. It is the shared technical baseline for the international university network anticipated in phase 2 of the SUIT initiative.

Note on the process: *This document is an always living document. It is provided for constructive feedback and revision in order to improve its quality. The engineering of this document was partially supported by digital tools, some of which incorporate Artificial Intelligence features.*

References

[1] Nicolas Guelfi. *Sovereign University IT — A Technical Reference for Architecture and Migration.* Technical reference and migration playbook. First version created by Nicolas Guelfi, Chairman of the SUIT Working Group, originally developed for the University of Luxembourg. Companion technical document to the report *Infrastructure and Organisation of Information Systems for a Research University.* Always-living document; version 2.1, May 2026. SUIT Working Group (first version developed at the University of Luxembourg), 2026.